

Política de Segurança da Informação e Proteção de Dados

ÓrbitaTech — Área Jurídica & Compliance | Documento interno de apoio ao agente corporativo (RAG)

1. Objetivo

Esta política estabelece as diretrizes internas de classificação, tratamento e proteção da informação corporativa e de dados pessoais (clientes e colaboradores), em conformidade com a Lei Geral de Proteção de Dados (LGPD - Lei nº 13.709/2018) e as boas práticas de segurança da informação da ÓrbitaTech.

2. Classificação da informação

- **Pública:** pode ser divulgada externamente sem restrição (ex: material de marketing).
- **Interna:** uso restrito a colaboradores(as) (ex: manuais operacionais, apresentações internas).
- **Confidencial:** acesso restrito a áreas específicas, mediante justificativa (ex: dados financeiros, contratos).
- **Restrita:** acesso individualizado e auditado (ex: dados pessoais sensíveis, dados de cartão de pagamento).

3. Tratamento de dados pessoais de clientes

O acesso a dados pessoais de clientes (CPF, endereço, histórico de compras) é restrito às áreas que necessitam desses dados para executar suas funções (Atendimento, Logística, Financeiro), sob controle de permissões nominal, nunca por login compartilhado.

É proibida a exportação de bases de dados de clientes para dispositivos pessoais, e-mails pessoais ou ferramentas não homologadas pela área de Tecnologia.

4. Tratamento de dados pessoais de colaboradores(as)

Dados de RH (folha de pagamento, avaliações de desempenho, dados de saúde ocupacional) são acessíveis apenas pela equipe de Pessoas & Cultura e pela liderança direta, no que for estritamente necessário à gestão da equipe.

5. Controles de acesso

- Autenticação multifator (MFA) obrigatória em todos os sistemas corporativos.
- Revisão trimestral de acessos por área, com revogação automática de contas inativas há mais de 60 dias.
- Acesso a bases de produção (bancos de dados) restrito à área de Tecnologia, mediante aprovação e registro em log.

6. Resposta a incidentes de segurança e vazamento de dados

Qualquer suspeita de incidente (perda de dispositivo, acesso indevido, e-mail suspeito, vazamento de dados) deve ser reportada imediatamente ao canal seguranca@orbitatech.com.br ou ao Comitê de Segurança da Informação.

- Passo 1 — Contenção: isolar o sistema ou conta comprometida em até 1 hora após identificação.
- Passo 2 — Avaliação de impacto: identificar quais dados e titulares foram afetados, em até 24 horas.
- Passo 3 — Comunicação: em caso de risco relevante a titulares, a Autoridade Nacional de Proteção de Dados (ANPD) e os titulares afetados são notificados em prazo razoável, conforme exigido pela LGPD.
- Passo 4 — Remediação e relatório final, com plano de ação para evitar recorrência.

7. Sanções por descumprimento

O descumprimento desta política pode resultar em advertência, suspensão, desligamento por justa causa e, quando aplicável, responsabilização civil e criminal, conforme a gravidade da violação e a legislação vigente.

8. Contatos

Encarregado de Dados (DPO): dpo@orbitatech.com.br | Segurança da Informação: seguranca@orbitatech.com.br | Canal de Ética (anônimo): etica@orbitatech.com.br